

Política de Contraseñas y Control de Accesos

Organización: VENMON NATURALMENTE SL **Aplicación:** SellerBrain (sellersbrain.io)
Responsable: Fernando Gil — fernando.gil@me.com **Versión:** 1.0 · **Fecha de aprobación:** 2026-07-29 · **Próxima revisión:** 2027-07-29 (anual)

1. Objetivo y alcance

Establecer los requisitos de autenticación, acceso y gestión de credenciales para todos los sistemas que procesan o almacenan información de las API de Amazon en SellerBrain: cuentas de Amazon (Seller Central y Solution Provider Portal), Cloudflare, Supabase, el repositorio de código y el correo electrónico asociado.

2. Requisitos de contraseñas

- **Longitud mínima de 12 caracteres**, con combinación de mayúsculas, minúsculas, números y al menos un **carácter especial**.
- **Únicas por servicio**: no se reutiliza la misma contraseña en varios sistemas.
- **Rotación anual** (caducidad máxima de 365 días) y rotación inmediata ante cualquier sospecha de compromiso.
- Gestión mediante un **gestor de contraseñas**; se prohíbe apuntarlas en texto plano o compartirlas por canales no seguros.

3. Autenticación multifactor (MFA)

La **MFA es obligatoria** en todas las cuentas con acceso a información de Amazon o a la infraestructura: - Amazon (Seller Central + Solution Provider Portal / cuenta de desarrollador), - Cloudflare, Supabase, el proveedor del repositorio de código (GitHub), y el correo electrónico vinculado a estas cuentas.

4. Control de accesos (mínimo privilegio)

- El acceso a la información de Amazon se concede **según la función** de cada persona; por defecto, solo el **responsable** tiene acceso a los sistemas de producción.
- Se aplica el principio de **mínimo privilegio**: cada cuenta y cada clave de servicio dispone solo de los permisos estrictamente necesarios (p. ej. la clave de servicio de Supabase se usa solo desde el backend).
- Los accesos se **revisan al menos una vez al año** y se revocan de inmediato cuando dejan de ser necesarios (bajas, cambios de rol).
- En la aplicación, cada vendedor accede **únicamente a sus propios datos** mediante Row Level Security (RLS) en la base de datos.

5. Gestión de credenciales y secretos

- Las credenciales y secretos (claves de API, **client secret**, claves de cifrado, tokens) se almacenan **únicamente en gestores de secretos**: variables/secretos de Cloudflare Workers.
- **Nunca** se guardan credenciales en repositorios públicos, ni se comparten, ni se escriben ("hardcodean") directamente en el código de la aplicación.
- Los **refresh tokens de cada vendedor** se guardan **cifrados con AES-GCM** en la base de datos; la clave de cifrado se conserva como secreto de entorno, separada de los datos.

6. Cifrado

- **En tránsito**: todo el tráfico usa **TLS 1.2 o superior** (HTTPS) entre navegador, Cloudflare, Supabase y las API de Amazon.
- **En reposo**: los tokens sensibles se cifran con **AES-GCM** a nivel de aplicación, sobre el cifrado en reposo que proporciona Supabase (PostgreSQL gestionado en la UE).

7. Revisión

Esta política se **revisa como mínimo una vez al año** y tras cualquier cambio relevante de infraestructura o proveedores.

8. Control de versiones

Versión	Fecha	Cambios
1.0	2026-07-29	Versión inicial.